

Trust Web: Reputation Through Usage

Architecture Brief v0.6.14 | Constructing a
Sybil-Resistant, Privacy-Aware Trust Model



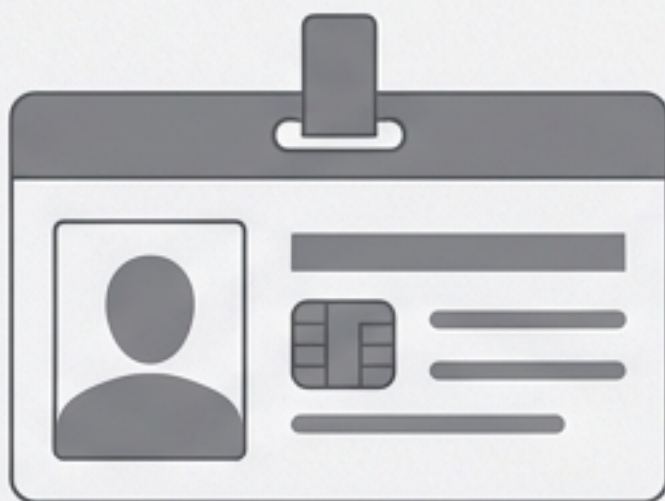
DATE: 23 Feb 2026

AUTHOR: Human (Project Lead)

TARGET AUDIENCE: Architect (Lead), AppSec, GRC

STATUS: Draft for Review

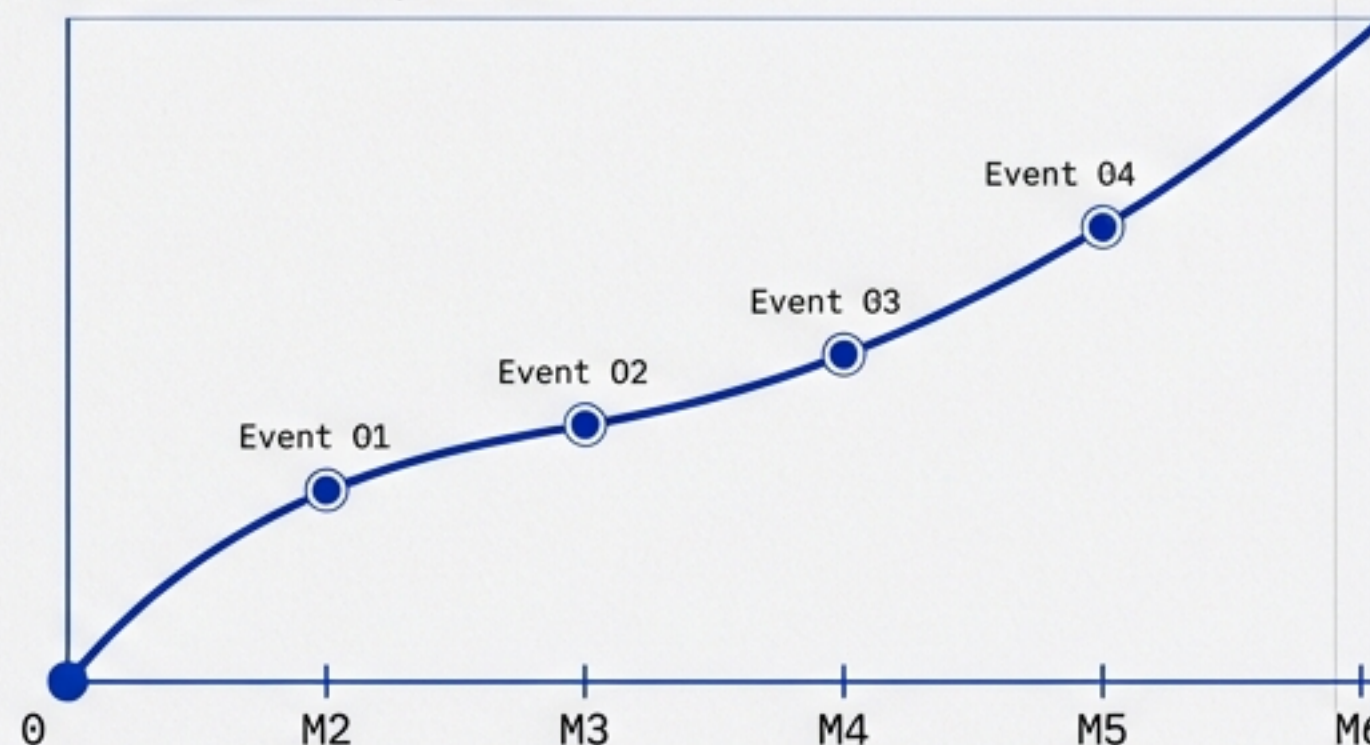
Access is a spectrum. Trust must be earned, not bought.



Paid Verification

I paid \$10, so I am trusted.

Behavioral Reputation

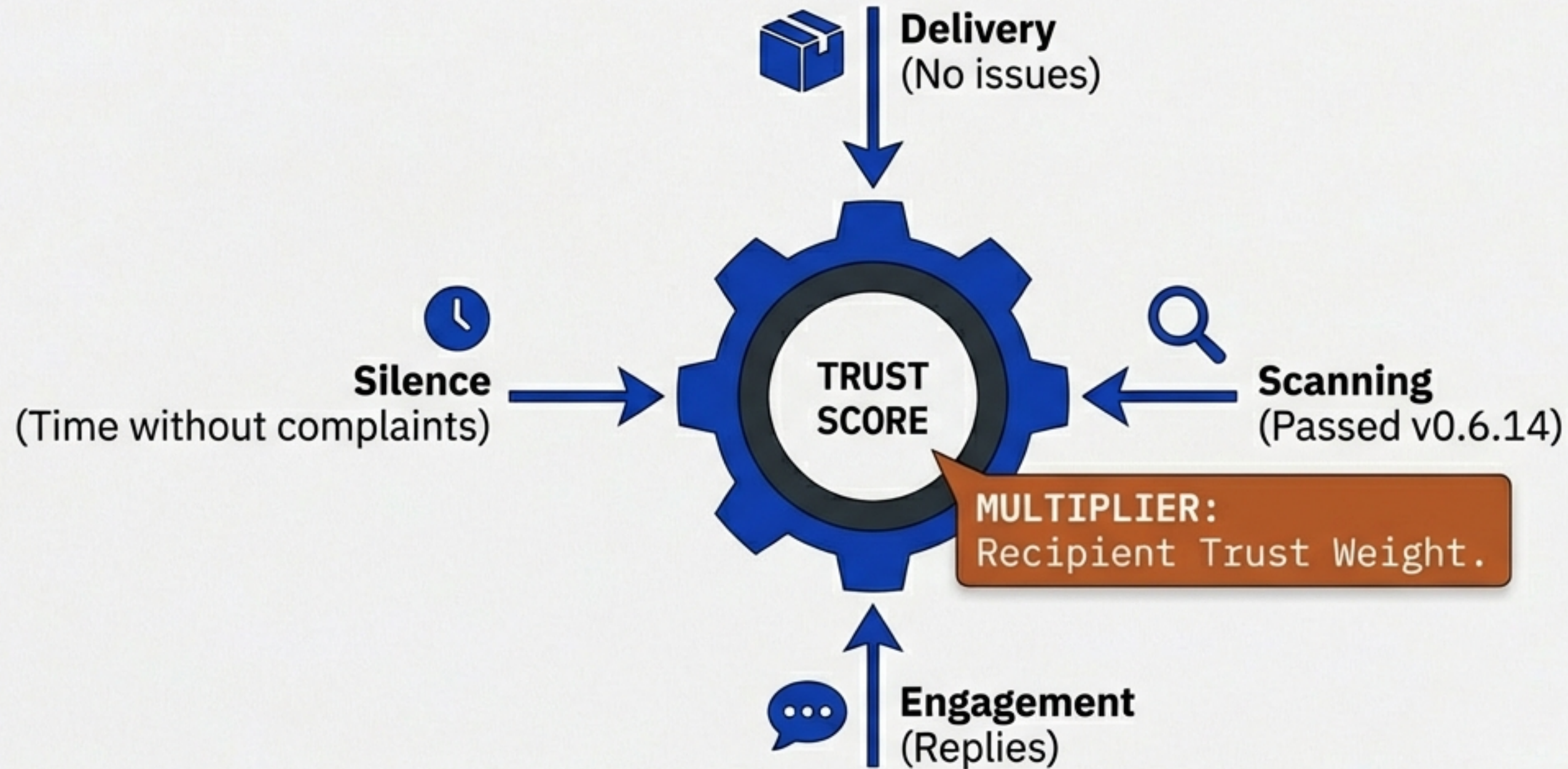


I delivered safe files for 6 months, so I am trusted.

Current systems rely on payment or static ID checks. The Trust Web relies on **usage**. Every successful file transfer builds trust; every complaint destroys it.

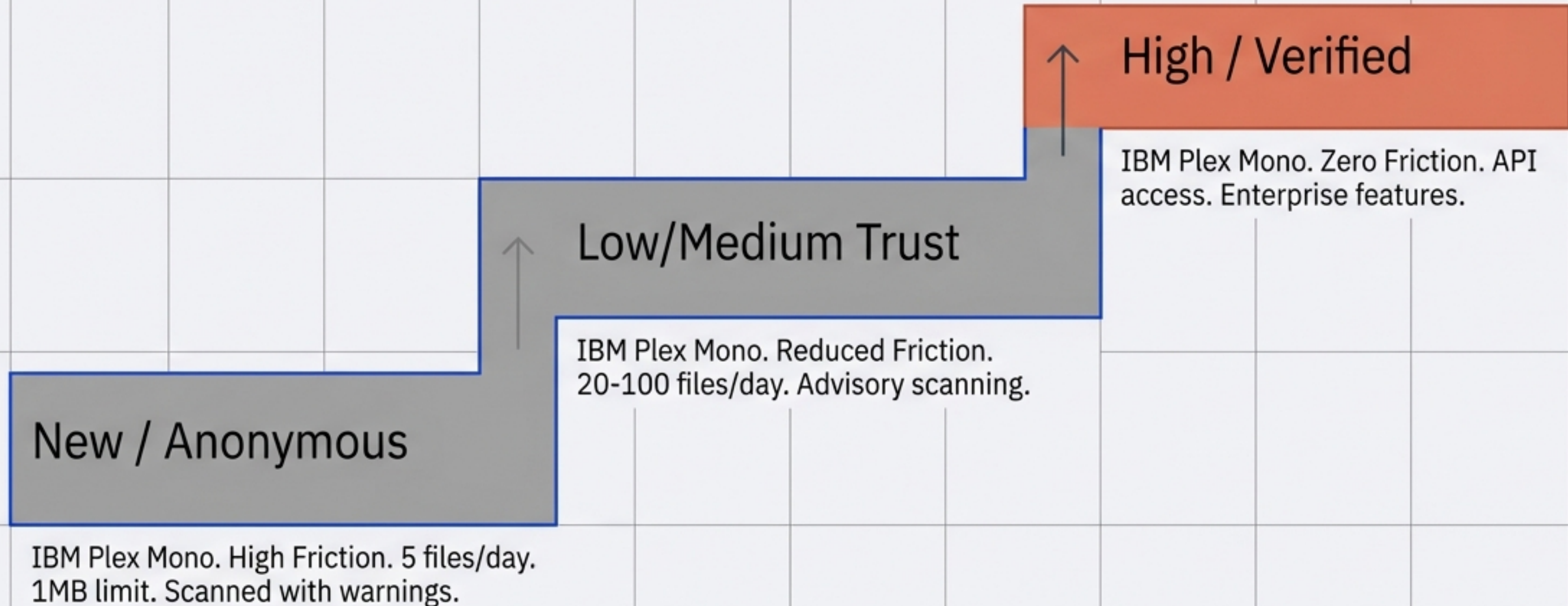
Insight: Attackers must invest time and effort to build fake networks—only to have them destroyed instantly upon detection.

Trust builds slowly through a feedback loop of positive signals.



Trust is not instantaneous. It is the aggregate of history. Interactions with already-trusted users count for more. Interactions with new users are neutral.

Capabilities scale directly with reputation.

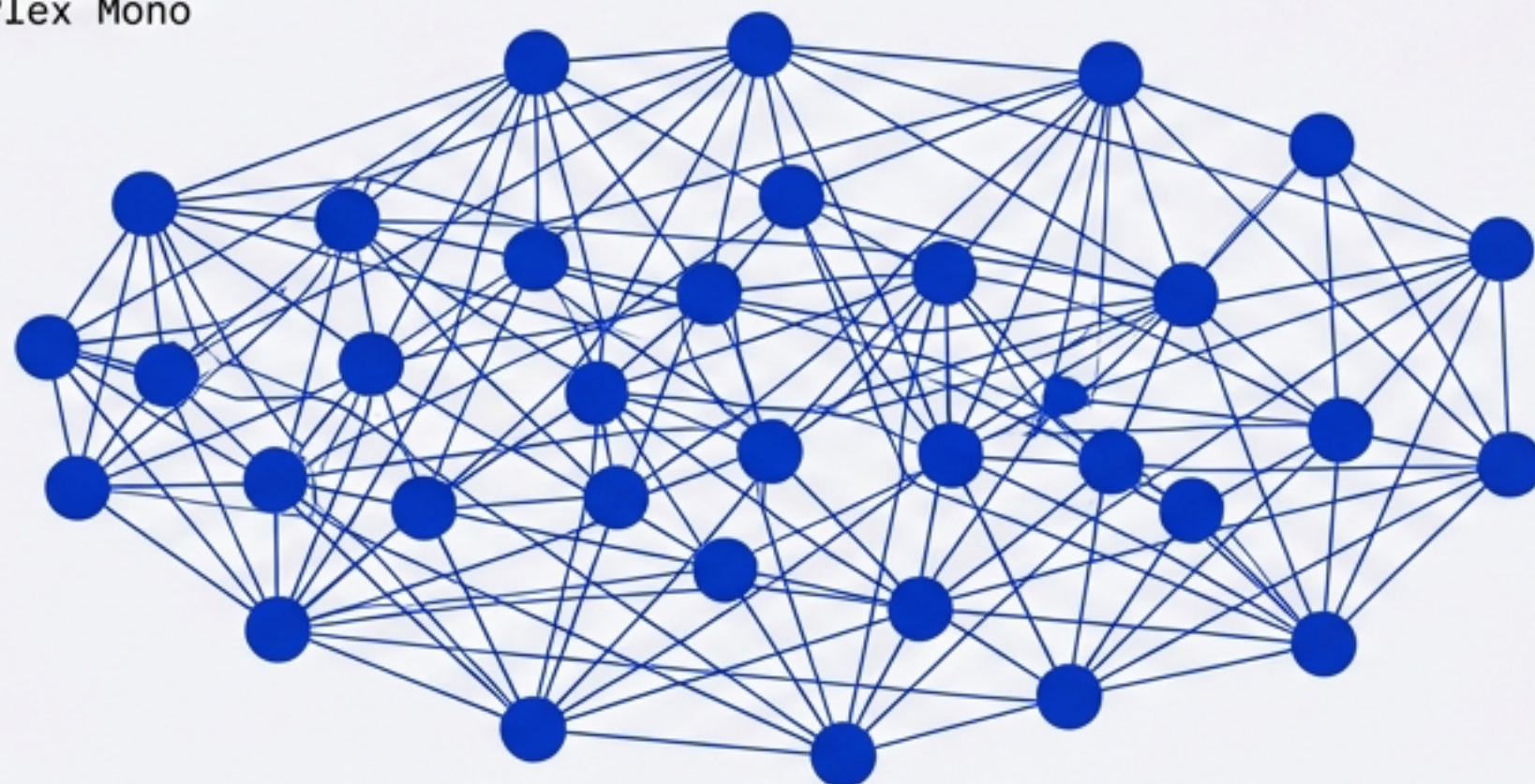


Rate limits act as a blast radius control. New accounts are physically incapable of causing massive damage.

The Web is the Defence.

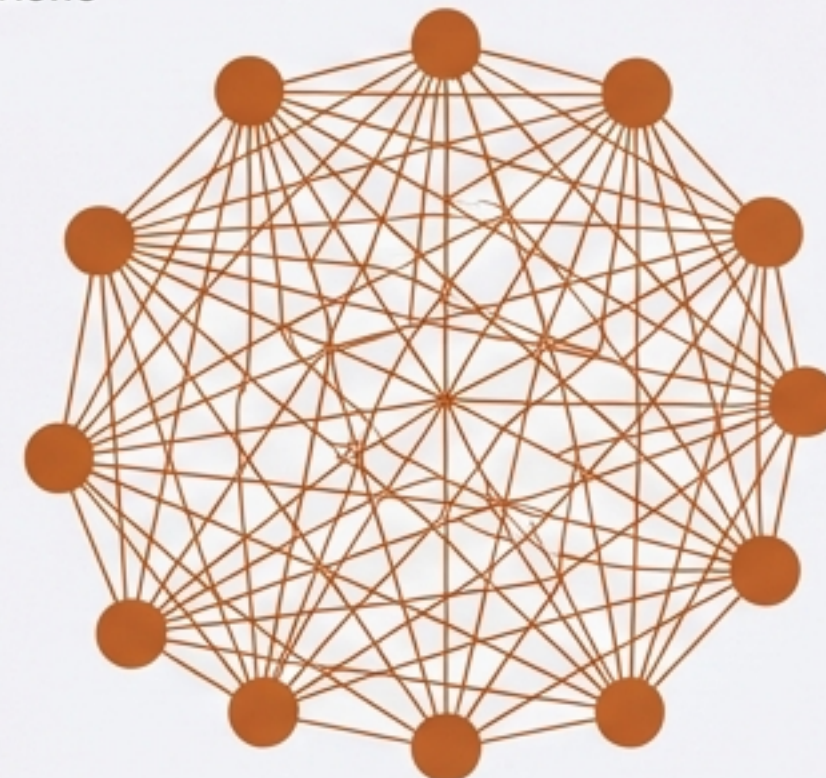
Trusted Cluster

IBM Plex Mono



Sybil Attack Cluster

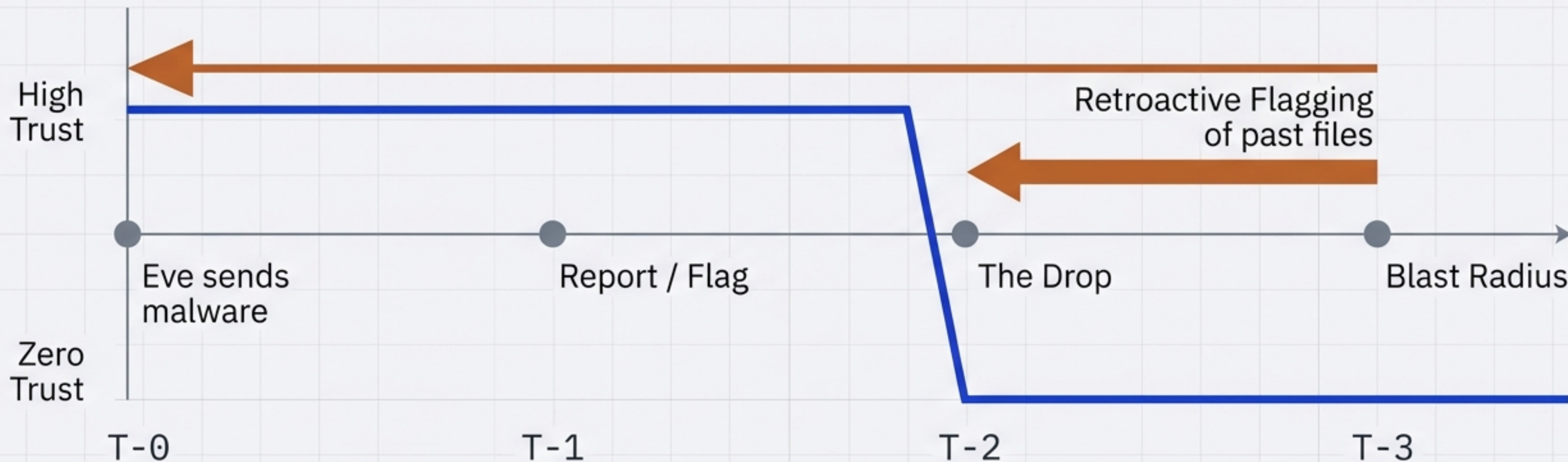
IBM Plex Mono



1. New accounts start at zero trust.
2. Trust derived from other new accounts is weighted near zero.
3. To gain real trust, you must interact with *already trusted* nodes.

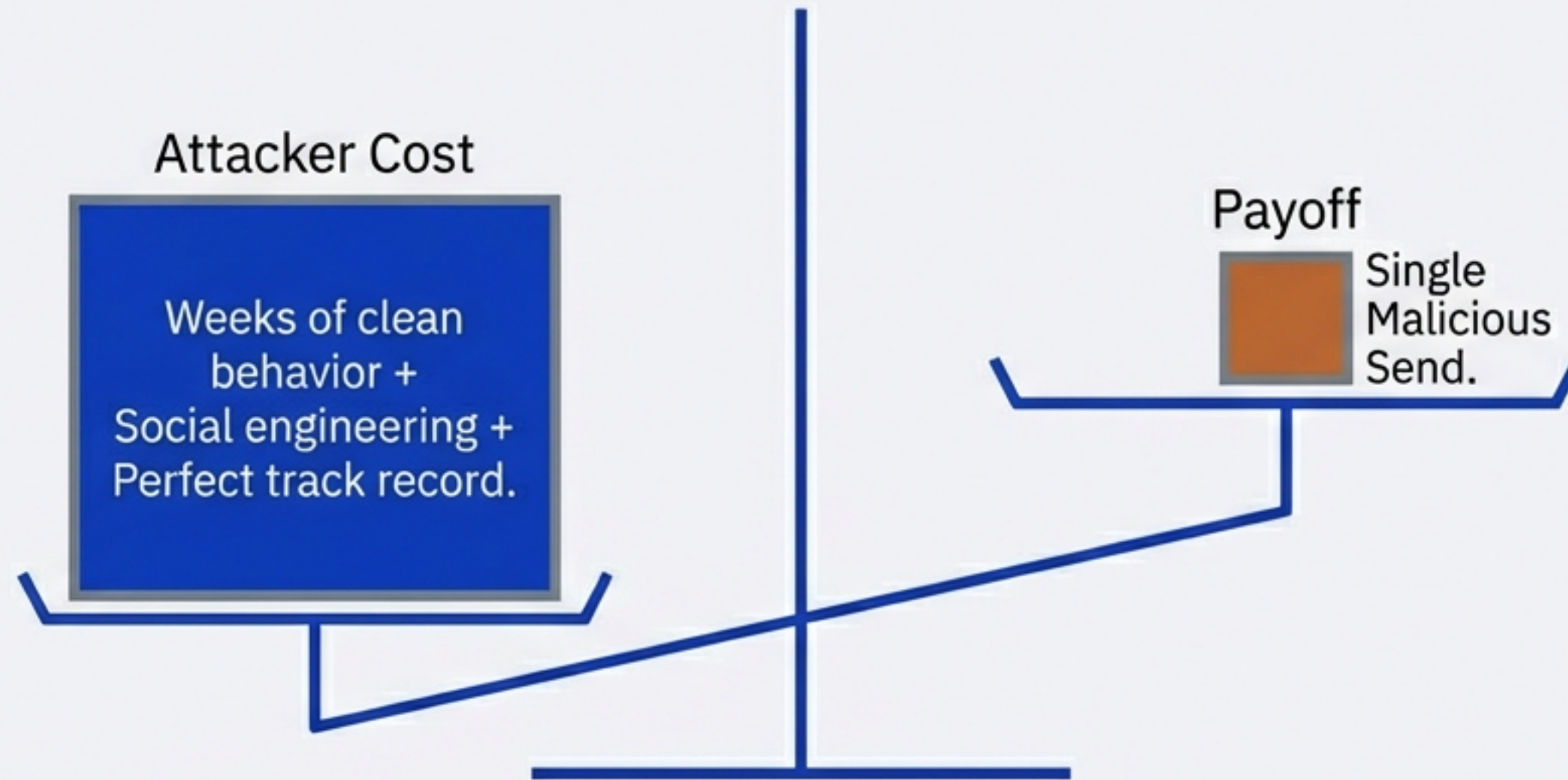
Creating 1,000 fake accounts achieves nothing if they only talk to each other.
The graph topology isolates them.

Trust is destroyed fast.



Eve loses her entire history and investment instantly.
She must restart from zero, with severe restrictions.

Making attacks expensive, fragile, and ROI-negative.

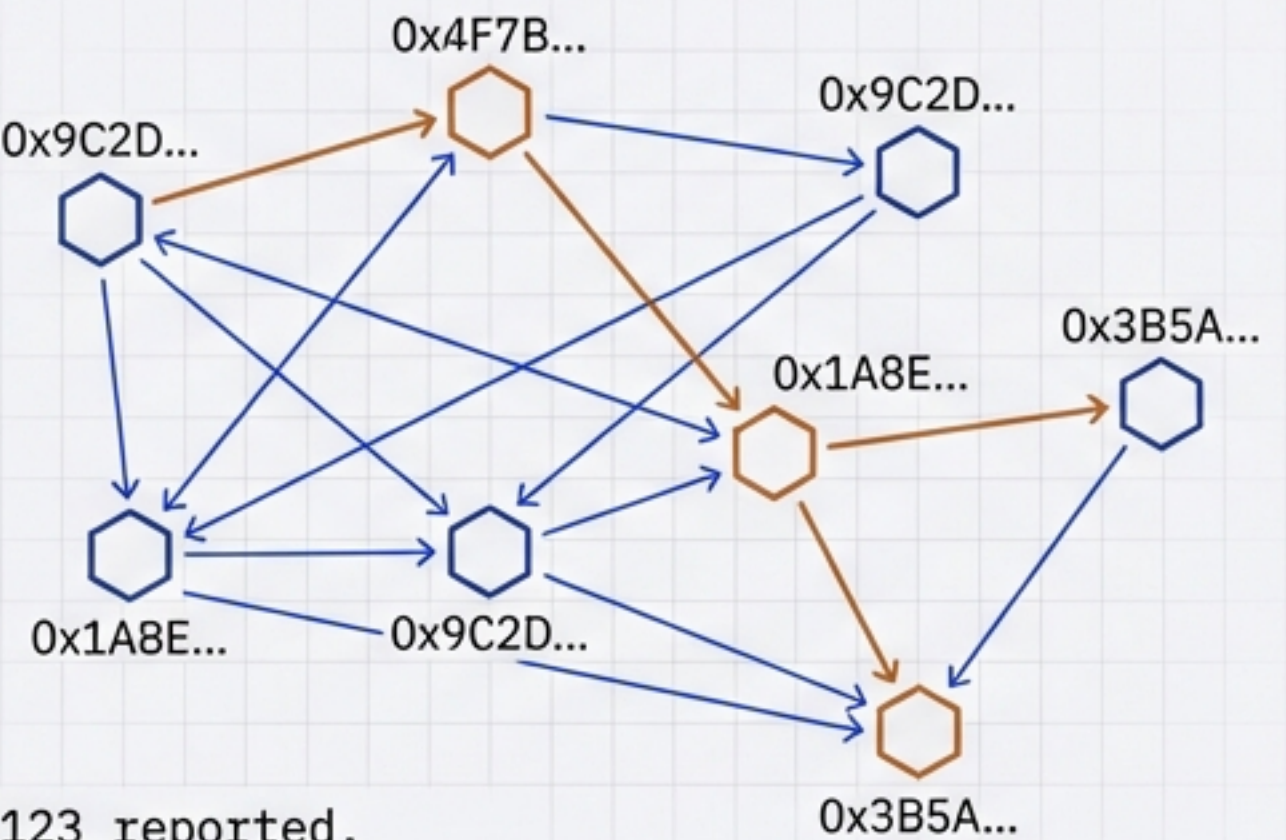


An attacker can 'farm' trust, but they must behave perfectly for weeks. The moment they execute their attack, the account is burned. The cost to build the reputation exceeds the value of the single attack.

The Privacy Trade-off: Metadata vs. Zero-Knowledge

Server View

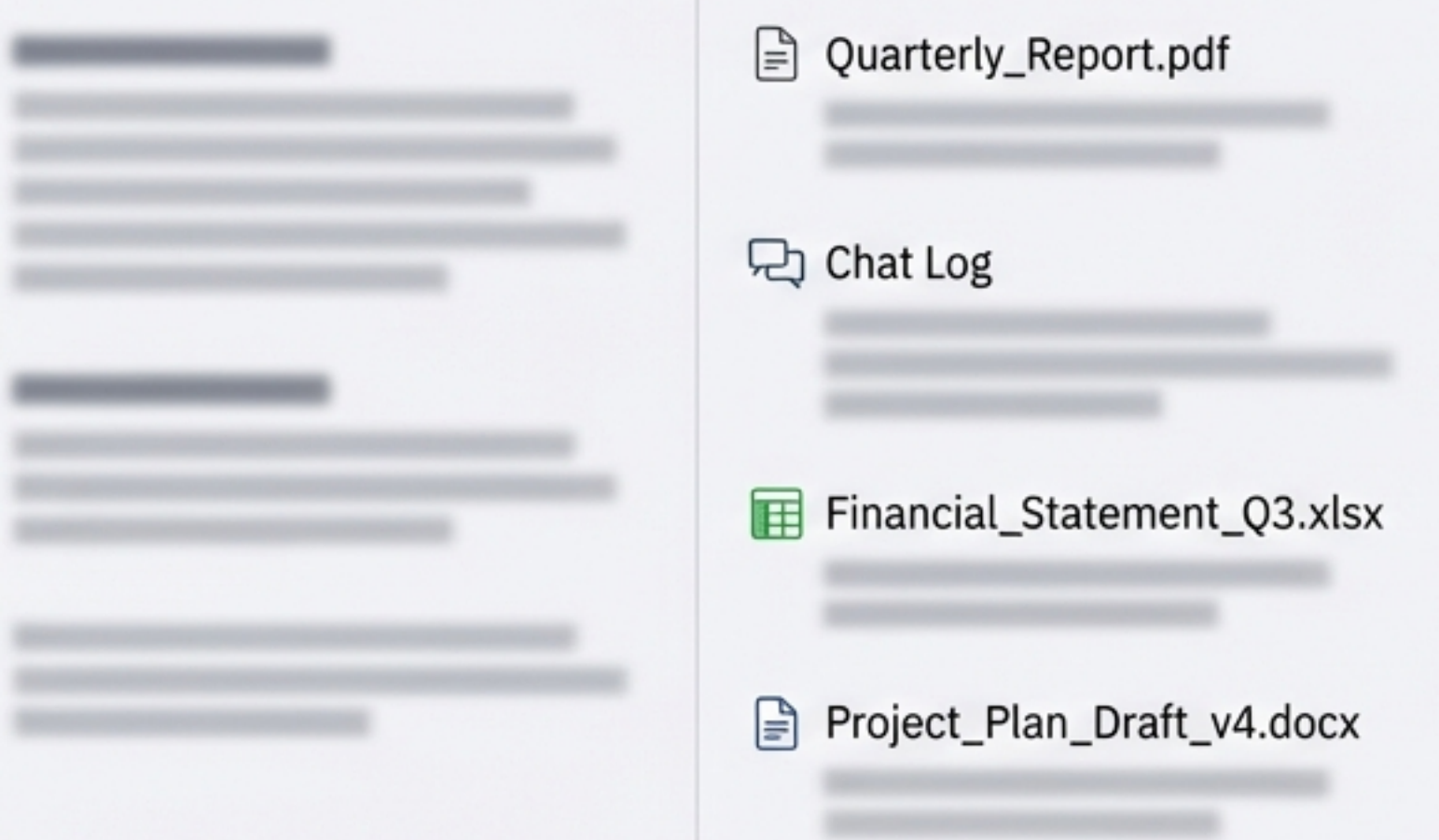
IBM Plex Sans



Obj_ID 123 reported.
0x7B... -> 0x9C...
Metadata: Topology Known

User View

IBM Plex Sans



Critical Decision: To compute the trust graph, the server **must** know the topology of who communicates with whom.

GRC Note: Analogous to an email server knowing the sender/recipient headers, but not the body of the email.

Data Residency & Partitioning

Server-Side (Public)

- Aggregate Trust Score (Integer).
- Queryable by Public Key.

Server-Side (Private)

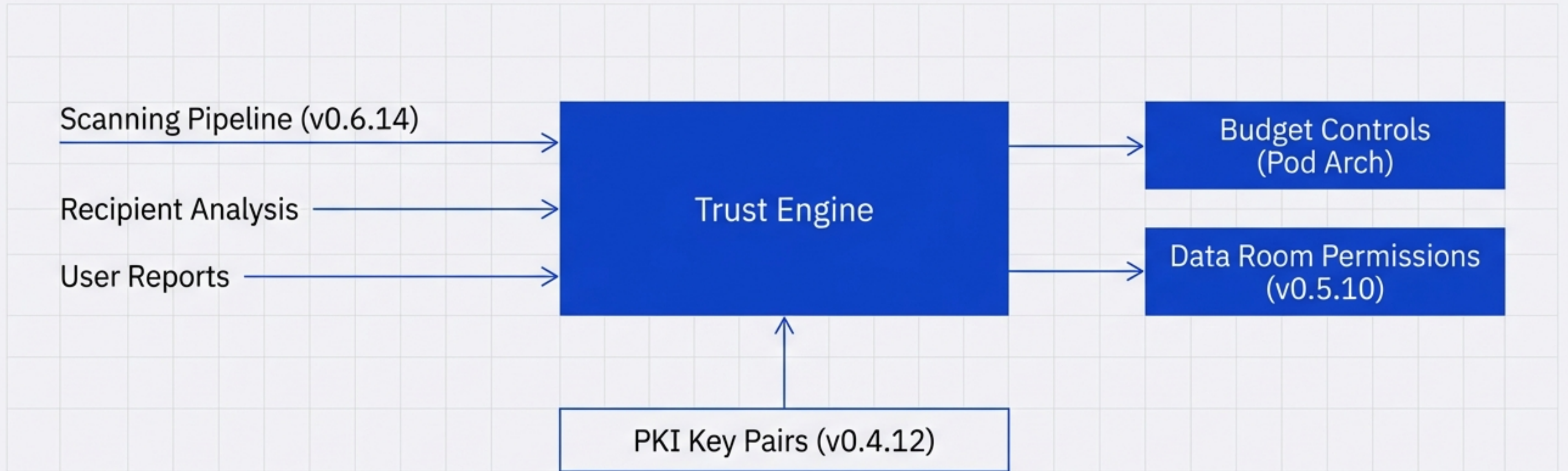
- Complaint Flags.
- Graph Edges (Metadata).
- Used for Computation.

Client-Side (Encrypted)

- Transaction History.
- Actual File Data.
- Decryption Keys.

Security Insight: The server knows the score, but not the specific human history that created it. Identity is tied to the Key Pair (v0.4.12+).

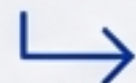
Connecting Trust to the Wider Architecture



Trust adheres to the Key, not an email address. Budget controls act as a hard cap; Trust acts as a dynamic soft cap.

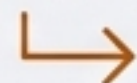
A Multi-Layered Security Posture

Threat: Sybil Attack



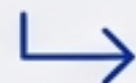
Mitigation: Recipient Trust Weight
(Fake clusters isolated).

Threat: Account Takeover



Mitigation: Sudden behavior
change detection.

Threat: Rogue Bot



Mitigation: Budget Controls &
Circuit Breakers.

Threat: Malware



Mitigation: Quarantine + Trust
Drop (Instant Burn).

Defenses act in concert to contain blast radius and de-incentivize abuse.

From Concept to Code



Objective: Validate the graph dynamics before turning on the enforcers.

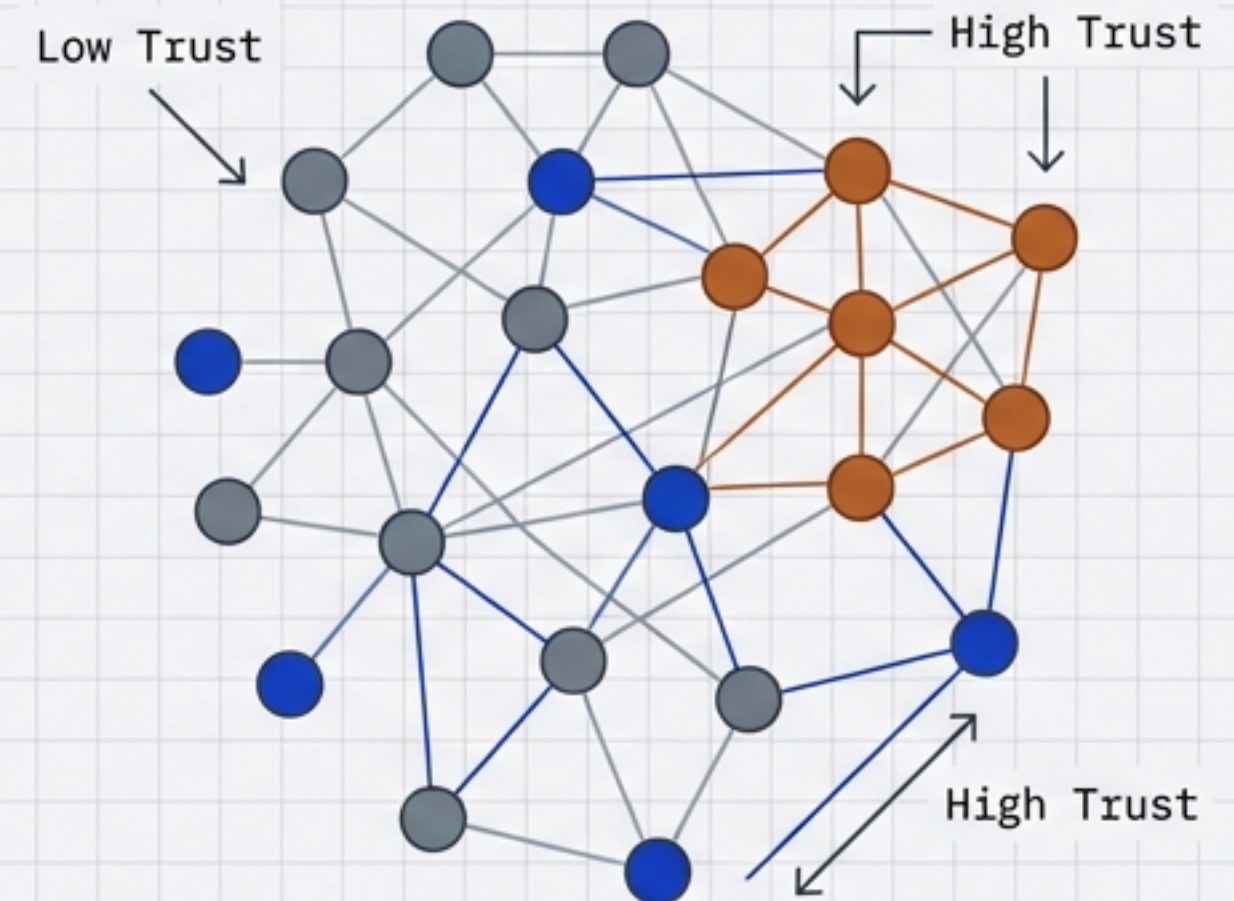
Definition of Done.

- ☐ Trust score model designed (formula, weights).
- ☐ Positive/Negative signals documented.
- ☐ Privacy trade-off documented & accepted by GRC.
- ☐ Sybil resistance verified (low-trust recipient analysis).
- ☐ Trust levels mapped to platform capabilities.

A community that defends itself.

By shifting from payment-based trust to usage-based trust, we make attacks economically unviable while preserving privacy for legitimate users.

- > **AppSec**: Validate Sybil parameters and 'burn' thresholds.
- > **GRC**: Sign off on metadata retention (topology vs. content).
- > **Product**: Define specific rate limits for 'Low' vs 'High' trust tiers.



Credits & Licence.

Based on Architecture Brief v0.6.14.

Released under Creative Commons Attribution 4.0
International (CC BY 4.0).

You are free to share and adapt this material for any
purpose, including commercially, as long as you give
appropriate credit.